Scenario 1: Auditing System Information and Installed Software

Background: As an IT auditor, you are tasked with assessing the system information and installed software on a set of Windows servers in your organization. This assessment aims to ensure that all systems are up-to-date with the latest service packs and patches, and to identify any unauthorized software installations.

Tasks:

1. **Collect System Information:**
   - Use the native Windows command to retrieve detailed system information, including the operating system version, installed service packs, and hardware details.
2. **List Installed Software:**
   - Utilize a command-line utility to list all installed applications on the system.
3. **Compare Installed Software Against Approved List:**
   - Compare the list of installed applications against the organization's approved software list to identify any unauthorized installations.

Solutions:

1. **Collect System Information:**
   - Open Command Prompt with administrative privileges.
   - Execute the following command:
     `systeminfo`
   - This command provides detailed information about the system, including OS version, service packs, and hardware components.
2. **List Installed Software:**
   - Download and extract the PsInfo utility from Sysinternals.
   - Navigate to the directory containing PsInfo.exe.
   - Run the following command:
     `psinfo -s`
   - The `-s` switch lists all installed applications on the system.
3. **Compare Installed Software Against Approved List:**
   - Export the output from PsInfo to a text file:
     `psinfo -s > installed_software.txt`
   - Open `installed_software.txt` and compare its contents against the organization's approved software list to identify any discrepancies.

Scenario 2: Auditing Running Processes and Services

Background: Your organization suspects that unauthorized processes and services might be running on certain Windows servers, potentially compromising security. You are assigned to audit the running processes and services to detect any anomalies.

Tasks:

1. **List Running Processes:**
   - Use a command-line utility to list all active processes on the system.
2. **List Installed Services:**
   - Utilize a command-line tool to enumerate all installed services, their statuses, and startup types.
3. **Identify Unauthorized Processes and Services:**
   - Compare the lists of processes and services against the organization's baseline to identify unauthorized or suspicious entries.

Solutions:

1. **List Running Processes:**
   - Download and extract the PsList utility from Sysinternals.
   - Navigate to the directory containing PsList.exe.
   - Execute the following command:
     `pslist`
   - This command displays all active processes along with details such as process ID and memory usage.
2. **List Installed Services:**
   - Download and extract the PsService utility from Sysinternals.

- Navigate to the directory containing PsService.exe.
- Run the following command:
  ```
  psservice enum
  ```
- This command lists all installed services, their current statuses (running or stopped), and startup types (auto, manual, or disabled).

3. **Identify Unauthorized Processes and Services:**
   - Export the outputs from PsList and PsService to text files:
     ```
     pslist > running_processes.txt
     psservice enum > installed_services.txt
     ```
   - Compare these files against the organization's baseline to identify any unauthorized or suspicious processes and services.

Scenario 3: Managing Stored Credentials

Background: During a security review, it was discovered that some users have stored credentials on their Windows machines, which could pose a security risk if not managed properly. You are tasked with auditing and managing these stored credentials.

Tasks:

1. **List Stored Credentials:**
   - Use a native Windows command to list all stored credentials for the current user.
2. **Delete Specific Stored Credentials:**
   - Identify and delete stored credentials that are deemed unnecessary or pose a security risk.

Solutions:

1. **List Stored Credentials:**
   - Open Command Prompt with user privileges.
   - Execute the following command:
     ```
     cmdkey /list
     ```
   - This command lists all stored credentials for the current user, including target names and credential types.
2. **Delete Specific Stored Credentials:**
   - Identify the target name of the credential to be deleted from the list obtained.
   - Run the following command to delete the specific credential:
     ```
     cmdkey /delete:target_name
     ```
   - Replace `target_name` with the actual target name of the credential to be removed.

Scenario 4: Auditing Network Configuration and Connections

Background: As part of a network security audit, you need to assess the network configuration and active connections on Windows servers to ensure compliance with security policies.

Tasks:

1. **Display Network Configuration:**
   - Use a native Windows command to display the current network configuration, including IP addresses, subnet masks, and gateways.
2. **List Active Network Connections:**
   - Utilize a command-line tool to list all active network connections and listening ports.

Solutions:

1. **Display Network Configuration:**
   - Open Command Prompt with administrative privileges.
   - Execute the following command:
     ```
     netsh interface ip show config
     ```
   - This command provides detailed information about the network interfaces, including IP addresses, subnet masks, gateways, and DNS settings.
2. **List Active Network Connections:**
   - Open Command Prompt with administrative privileges.
   - Run the following command:
     ```
     netstat -ano
     ```

- This command lists all active network connections, including local and remote IP addresses, connection states, and associated process IDs (PIDs).

3. **Identify Unauthorized Connections:**
   - Compare the list of active connections against known legitimate IP addresses and services.
   - Identify suspicious connections, particularly those in an "ESTABLISHED" state that communicate with unknown external IPs.
4. **Trace the Process Associated with a Connection:**
   - Once a suspicious connection is identified, find the associated process using its PID:
     `tasklist | findstr "PID"`
   - Replace `"PID"` with the actual process ID.
5. **Block Unwanted Network Access:**
   - If unauthorized network activity is detected, use `netsh` to block the specific IP address:
     `netsh advfirewall firewall add rule name="Block Suspicious IP" dir=out action=block remoteip=xxx.xxx.xxx.xxx`
   - Replace `xxx.xxx.xxx.xxx` with the actual suspicious IP.

Scenario 5: Auditing Services and Security Policies

Background:

Your organization requires an audit of Windows services and local security policies to ensure compliance with security best practices. Your task is to review all services running on the system and analyze the local security policies to detect potential vulnerabilities.

Tasks:

1. **List Installed Services and Their Statuses:**
   - Use a command-line tool to retrieve details about all installed services, including their startup type and current state.
2. **Check Service Permissions and Security Configurations:**
   - Identify misconfigured services that could be exploited by attackers.
3. **Audit Local Security Policies:**
   - Use a built-in Windows command to review the applied security policies on the system.

Solutions:

1. **List Installed Services and Their Statuses:**
   - Open Command Prompt with administrative privileges.
   - Run the following command:
     `sc query state= all`
   - This command lists all installed services along with their statuses (RUNNING, STOPPED, etc.).
2. **Retrieve Detailed Information About a Specific Service:**
   - If a specific service requires deeper investigation, use the following command:
     `sc qc "ServiceName"`
   - Replace `"ServiceName"` with the actual name of the service.
3. **Analyze Local Security Policies:**
   - Open Command Prompt and execute:
     `secpol.msc`
   - This opens the Local Security Policy Manager, where policies related to user rights, audit settings, and security options can be reviewed.
4. **List the Resulting Set of Security Policies:**
   - Use the following command to generate a report of the security policies applied to the system:
     `rsop.msc`
   - This command launches the Resultant Set of Policy (RSOP) tool, which provides a comprehensive overview of group policies affecting the system.
5. **Identify and Fix Misconfigured Policies:**
   - Review audit policies to ensure logging is enabled for critical security events.
   - Identify weak password policies, unauthorized user access permissions, or disabled security settings and modify them accordingly.

Scenario 6: Auditing Running Processes and Port Usage

Background:

Your organization suspects that a compromised Windows server is running hidden malicious processes that are communicating over unusual network ports. As an IT auditor, you must analyze all running processes and determine which processes are using network ports. Your investigation must include identifying unknown or unauthorized applications running in the background.

Tasks:

1. **Enumerate All Running Processes:**
   - List all currently running processes, along with their process IDs (PIDs) and CPU usage.
2. **Identify Network Ports in Use:**
   - Determine which network ports are being used and the processes associated with them.
3. **Investigate Suspicious Processes:**
   - Identify any processes that are not recognized or seem to be consuming excessive resources.
4. **Cross-Check Against Known Applications:**
   - Compare running processes with the organization's list of approved applications to detect unauthorized software.

Solutions:

1. **List Running Processes Using Process Explorer:**
   - Download **Process Explorer** from Sysinternals.
   - Run **procexp.exe** with administrative privileges.
   - Analyze running processes, CPU usage, and memory consumption.
   - Look for processes with suspicious names or excessive resource consumption.
2. **Identify Processes Using Network Ports:**
   - Open Command Prompt and execute the following command:
     `netstat -ano`
   - This command lists active connections, including the local and remote addresses, port numbers, and associated process IDs (PIDs).
3. **Map PIDs to Process Names:**
   - Use the following command to find which process is using a specific PID:
     `tasklist | findstr "PID"`
   - Replace `"PID"` with the actual process ID from the `netstat` output.
4. **Check for Unknown Processes Using Fport:**
   - Download and install **Fport** from Foundstone.
   - Run the following command:
     `fport`
   - This command maps processes to the ports they are using, helping to identify unauthorized network activity.
5. **Investigate and Terminate a Suspicious Process:**
   - If a process is found to be unauthorized or malicious, it can be terminated using:
     `taskkill /PID 1234 /F`
   - Replace `1234` with the actual PID.

Scenario 7: Auditing Scheduled Tasks for Malicious Activity

Background:

A recent security breach revealed that attackers had scheduled malicious scripts to execute at regular intervals on compromised Windows servers. Your job is to audit all scheduled tasks to identify any unauthorized or suspicious tasks.

Tasks:

1. **List All Scheduled Tasks:**
   - Identify all scheduled tasks running on the system.
2. **Analyze Task Execution Details:**

- Determine when tasks are set to run and what commands they execute.

3. **Compare Against Approved Tasks:**
   - Cross-check scheduled tasks against an organization-approved task list.
4. **Disable or Remove Malicious Tasks:**
   - If an unauthorized task is found, prevent it from executing.

Solutions:

1. **List All Scheduled Tasks Using schtasks:**
   - Open Command Prompt with administrative privileges and run:
     `schtasks /query /fo LIST /v`
   - This command provides detailed information about scheduled tasks, including their triggers and execution history.
2. **Export the Task List to a File for Analysis:**
   - Run the following command to save the task list to a file for easier comparison:
     `schtasks /query /fo csv /v > scheduled_tasks.csv`
   - Open `scheduled_tasks.csv` in a spreadsheet to analyze task names and execution details.
3. **Investigate Suspicious Tasks:**
   - Look for tasks running unknown scripts, batch files, or PowerShell commands.
   - Identify tasks executing at unusual times (e.g., late at night or outside business hours).
4. **Disable or Delete Unauthorized Tasks:**
   - Disable a suspicious task:
     `schtasks /change /tn "MaliciousTask" /disable`
   - Delete a malicious task:
     `schtasks /delete /tn "MaliciousTask" /f`
   - Replace `"MaliciousTask"` with the actual task name.

Scenario 8: Auditing Boot Configuration for Rootkits

Background:

A security incident has raised concerns that a rootkit might be altering the boot configuration on certain Windows machines. As an IT auditor, your goal is to review and secure the boot settings to prevent unauthorized modifications.

Tasks:

1. **List Boot Configuration Settings:**
   - Retrieve and analyze the current boot configuration.
2. **Check for Unauthorized Boot Entries:**
   - Look for unknown or hidden boot entries that could indicate malware presence.
3. **Restore Boot Configuration if Necessary:**
   - Remove any unauthorized boot entries and restore system integrity.

Solutions:

1. **List Boot Configuration Using bootcfg:**
   - Open Command Prompt with administrative privileges.
   - Run the following command:
     `bootcfg /query`
   - Review the boot entries listed and compare them against a standard, known-good configuration.
2. **Identify and Remove Unauthorized Boot Entries:**
   - If an unknown entry is found, remove it using:
     `bootcfg /delete /ID 2`
   - Replace `2` with the ID of the suspicious entry.
3. **Secure Boot Settings:**
   - Enable secure boot if disabled:
     `bcdedit /set {current} bootstatuspolicy IgnoreAllFailures`
   - This command ensures that unauthorized changes are not ignored.

Scenario 9: Auditing Pending File Operations After a Reboot

Background:
After a recent malware attack, some files appear to be replaced or modified upon system reboot. You need to analyze pending file operations to detect any scheduled file moves or deletions that might be part of a persistence mechanism.

Tasks:

1. **List Pending File Move Operations:**
   - Identify files that are scheduled to be replaced or moved on the next system reboot.
2. **Analyze the Files Being Modified:**
   - Cross-check the listed files against malware signatures or unauthorized modifications.
3. **Prevent Malicious Modifications:**
   - Remove or modify any unauthorized pending file changes.

Solutions:

1. **List Pending File Operations Using pendmoves:**
   - Download **pendmoves.exe** from Sysinternals.
   - Run the following command:
     `pendmoves`
   - This command lists all file operations scheduled for the next reboot.
2. **Analyze the Listed Files:**
   - Check if any listed files are system-critical files (e.g., `explorer.exe`, `winlogon.exe`).
   - Compare against known clean versions using file hashes.
3. **Remove Unauthorized Pending Moves:**
   - If an unauthorized modification is found, delete the pending move entry manually before rebooting.

Scenario 10: Auditing Autorun Entries for Persistence Mechanisms
Background:
An incident response team suspects that malware is persisting on a system by injecting itself into autorun entries. Your task is to audit all autorun programs and identify any malicious entries.

Tasks:

1. **List All Autorun Entries:**
   - Identify applications set to launch automatically at startup.
2. **Analyze Suspicious Entries:**
   - Cross-check against a whitelist of approved startup programs.
3. **Remove or Disable Unauthorized Autorun Entries:**
   - Prevent any malicious programs from executing at startup.

Solutions:

1. **List Autorun Entries Using Autorunsc:**
   - Download **Autorunsc.exe** from Sysinternals.
   - Run the following command:
     `autorunsc -a`
   - This command lists all startup programs and their locations.
2. **Analyze Entries for Malicious Programs:**
   - Check the program paths for executables in unusual directories (e.g., `%AppData%`, `%Temp%`).
3. **Disable Malicious Autorun Entries:**
   - Run the following command to disable a specific entry:
     `autorunsc -d "MaliciousEntry"`
   - Replace `"MaliciousEntry"` with the actual entry name.

Scenario 11: Auditing Unauthorized Network Activity Using TCPView and Netstat
Background:
A security operations team has detected unusual spikes in outbound network traffic on a Windows server. The concern is that an attacker might have installed a backdoor or malware that is exfiltrating sensitive data. Your

task as an IT auditor is to investigate this suspicious network activity, identify unknown remote connections, and take remedial actions if required.

Tasks:

1. **Identify Active Network Connections and Their Associated Processes:**
   - Determine which applications are communicating with external IPs.
2. **Monitor Network Connections in Real-Time:**
   - Observe active connections to detect unusual patterns or unauthorized communication.
3. **Analyze and Terminate Suspicious Connections:**
   - Identify and investigate unapproved remote connections.
4. **Prevent Further Unauthorized Access:**
   - Block suspicious IPs and restrict outbound traffic.

Solutions:

1. **List All Active Network Connections with Process IDs:**
   - Open Command Prompt with administrative privileges and run:
     `netstat -ano`
   - This command displays all active network connections, along with their associated process IDs (PIDs).
2. **Identify the Process Behind a Suspicious Connection:**
   - Find which process is using a specific PID:
     `tasklist | findstr "1234"`
   - Replace `1234` with the actual PID from the `netstat` output.
3. **Monitor Network Traffic in Real-Time Using TCPView:**
   - Download and run **TCPView** from Sysinternals.
   - Observe open network connections and look for rapid data transfers to unknown external IPs.
4. **Investigate and Terminate the Malicious Process:**
   - If a suspicious process is identified, terminate it:
     `taskkill /PID 1234 /F`
5. **Block Unauthorized Remote IPs:**
   - Use the following command to add a firewall rule blocking suspicious IPs:
     `netsh advfirewall firewall add rule name="Block Malicious IP" dir=out action=block remoteip=xxx.xxx.xxx.xxx`
   - Replace `xxx.xxx.xxx.xxx` with the actual suspicious IP.

Scenario 12: Investigating Unauthorized Service Modifications Using PsService and Sc

Background:

An IT administrator suspects that a recent security breach allowed an attacker to modify Windows services, potentially installing a malicious service that persists after reboots. You are tasked with auditing all installed services and identifying any unauthorized or suspicious services.

Tasks:

1. **List All Installed Services and Their Configurations:**
   - Retrieve a complete list of services running on the system.
2. **Identify Unauthorized Services:**
   - Cross-check installed services against a list of approved services.
3. **Analyze Service Permissions and Dependencies:**
   - Identify services running under high-privilege accounts.
4. **Disable or Remove Unauthorized Services:**
   - Prevent any malicious services from running.

Solutions:

1. **List Installed Services Using PsService:**
   - Download **PsService** from Sysinternals.
   - Run the following command:
     `psservice list`
   - This command lists all installed services, including their statuses.

2. **Retrieve Detailed Information About a Specific Service:**
    - If a suspicious service is found, analyze it:
      `psservice query "SuspiciousService"`
    - Replace `"SuspiciousService"` with the actual service name.
3. **Verify Service Configuration Using Sc:**
    - Retrieve configuration details:
      `sc qc "SuspiciousService"`
    - This command provides information about the service binary path, startup type, and associated privileges.
4. **Disable or Remove a Malicious Service:**
    - Stop the service:
      `sc stop "SuspiciousService"`
    - Disable it permanently:
      `sc config "SuspiciousService" start= disabled`
    - Delete it if necessary:
      `sc delete "SuspiciousService"`

Scenario 13: Auditing Local Security Settings Using DumpSec
Background:
Your security team needs to conduct an in-depth audit of a Windows system's security settings, including user permissions, password policies, and file access control lists (ACLs). A recent internal review indicated that some accounts might have excessive privileges, creating security risks.
Tasks:

1. **List Local User Accounts and Their Group Memberships:**
    - Identify users with administrative privileges.
2. **Review Password Policy Settings:**
    - Verify password complexity, expiration, and lockout policies.
3. **Analyze NTFS Permissions on Critical Files:**
    - Identify any sensitive files that are improperly accessible.
4. **Generate an Audit Report for Compliance Review:**
    - Provide a report of findings for IT security management.

Solutions:

1. **List User Accounts and Groups Using DumpSec:**
    - Download and install **DumpSec** from SomarSoft.
    - Run the following command to list users and group memberships:
      `DumpSec /rpt=users`
2. **Check Password Policies:**
    - Run the following command to retrieve password policy settings:
      `net accounts`
    - Look for settings like "Maximum password age" and "Minimum password length."
3. **Audit NTFS Permissions on Sensitive Files:**
    - Run DumpSec to list file ACLs:
      `DumpSec /rpt=files /path="C:\SensitiveData"`
    - Replace `"C:\SensitiveData"` with the actual directory path.
4. **Generate a Security Report for Review:**
    - Export findings to a file:
      `DumpSec /rpt=all > SecurityReport.txt`

Scenario 14: Auditing Startup Programs for Persistence Using Autoruns
Background:
A malware infection was recently detected on a Windows machine. After removal, users still report unusual behavior at startup. Your task is to investigate whether the malware is set to run automatically when the system boots up.

Tasks:

1. **List All Startup Programs and Registry Autorun Entries:**
   - Identify programs that launch at startup.
2. **Analyze Suspicious Startup Entries:**
   - Cross-check against a list of approved startup programs.
3. **Disable or Remove Malicious Entries:**
   - Prevent any unauthorized programs from starting at boot.

Solutions:

1. **List All Startup Programs Using Autoruns:**
   - Download **Autoruns** from Sysinternals.
   - Run the following command:
     ```
     autorunsc -a
     ```
   - This command lists all startup programs, including those in the registry.
2. **Investigate Unknown Entries:**
   - Check program paths for executables in `%AppData%`, `%Temp%`, or `C:\Users\Public`.
3. **Disable Malicious Autorun Entries:**
   - Run the following command to disable a specific entry:
     ```
     autorunsc -d "MaliciousEntry"
     ```

Scenario 15: Investigating Security Policy Compliance Using RSOP

Background:

A recent compliance audit raised concerns that some security policies might not be applied correctly on a Windows system. Your job is to investigate the active Group Policy settings and ensure compliance with security best practices.

Tasks:

1. **Retrieve the Resultant Set of Policies (RSOP):**
   - Identify which policies are applied to the system.
2. **Analyze Security Settings:**
   - Verify password policies, account lockout settings, and audit logging.
3. **Identify Policy Conflicts or Overrides:**
   - Determine if any local policies override domain security settings.

Solutions:

1. **Open RSOP for Analysis:**
   - Run the following command:
     ```
     rsop.msc
     ```
   - This command displays applied Group Policies.
2. **Review Password and Lockout Policies:**
   - Navigate to:
     ```
     Computer Configuration → Windows Settings → Security Settings → Account Policies
     ```
3. **Fix Policy Issues:**
   - If a policy is not applied correctly, force an update:
     ```
     gpupdate /force
     ```

Scenario 16: Detecting Unauthorized Software Installations Using Secpol.msc and PsInfo

Background:

A financial institution has strict policies on software installations, only allowing pre-approved applications. However, an employee has reported seeing unauthorized software on their machine. Your task as an IT auditor is to investigate whether unauthorized software has been installed on company computers and whether security policies were bypassed.

Tasks:

1. **List All Installed Software and Updates:**

- Identify unauthorized software and installations.

2. **Check if Security Policies Were Modified to Allow Unauthorized Installs:**
   - Review policy settings for software installation restrictions.
3. **Determine Who Installed the Unauthorized Software and When:**
   - Check system logs and user activity.
4. **Prevent Future Unauthorized Software Installations:**
   - Ensure security policies enforce restrictions.

Solutions:

1. **List Installed Software and Updates Using PsInfo:**
   - Open **Command Prompt** as an administrator and run:
     `psinfo -s`
   - This will list all installed software, service packs, and updates.
2. **Check for Software Restriction Policies Using Secpol.msc:**
   - Open **Run** (`Win + R`), type:
     `secpol.msc`
   - Navigate to:
     `Security Settings → Software Restriction Policies`
   - Verify that restrictions are in place for unauthorized installations.
3. **Audit Logins and Software Installation Attempts:**
   - Open Event Viewer (`eventvwr.msc`) and check logs under:
     `Windows Logs → Application and Security`
   - Look for event IDs related to software installations.
4. **Reinforce Policy Restrictions:**
   - To enable stricter control, apply execution restrictions:
     `secpol.msc → Security Settings → Software Restriction Policies → Enforcement`
   - Set to "All users except local administrators" to prevent unauthorized software installs.

Scenario 17: Investigating System Boot Modifications Using Bootcfg

Background:

An IT security audit has raised concerns that a compromised Windows system may have been modified to run an unauthorized dual-boot setup or an altered bootloader. Your job is to inspect the boot configuration and ensure the system has not been tampered with.

Tasks:

1. **Retrieve Boot Configuration Information:**
   - Identify any unauthorized modifications.
2. **Analyze Boot Entries and Startup Settings:**
   - Verify if unknown OS boot options exist.
3. **Detect Unauthorized Kernel Debugging or Safe Mode Manipulation:**
   - Check for altered debugging and safe mode settings.
4. **Remove Malicious or Unauthorized Boot Entries:**
   - Restore correct system boot settings.

Solutions:

1. **List Current Boot Configuration:**
   - Run the following command in **Command Prompt (Admin)**:
     `bootcfg /query`
   - Review the output for any unknown boot entries or OS installations.
2. **Check for Debugging or Safe Mode Modifications:**
   - Run:
     `bcdedit`
   - Look for unusual entries such as `/debug` or `/safeboot`.
3. **Remove Unauthorized Boot Entries:**
   - If an unknown entry is found, remove it using:
     `bootcfg /delete /id 2`

- Replace `2` with the appropriate boot ID from `bootcfg /query`.

4. **Restore Default Boot Settings (If Necessary):**
   - If malicious modifications are found, reset the bootloader:
     ```
     bootrec /fixmbr
     bootrec /fixboot
     bootrec /rebuildbcd
     ```

Scenario 18: Tracking File Movements on Next Reboot Using PendMoves
Background:
A forensic investigator suspects that an attacker has scheduled the deletion or movement of critical system files on the next reboot to cover their tracks. Your task is to analyze pending file operations and prevent critical data loss.
Tasks:

1. **Identify Pending File Moves or Deletions:**
   - Check scheduled file modifications for the next reboot.
2. **Verify If System Files or Logs Are Targeted:**
   - Identify if critical files (e.g., `system32`, event logs) are affected.
3. **Prevent the Attack by Reversing File Operations:**
   - Restore any critical file paths before rebooting.

Solutions:

1. **Check Pending File Moves:**
   - Run the following command to list scheduled file operations:
     ```
     pendmoves
     ```
2. **Identify Malicious File Deletions or Modifications:**
   - If system files or logs are listed in the output, take immediate action.
3. **Restore Files Before Rebooting:**
   - If a critical system file is set to be moved or deleted, use the following to restore from a backup:
     ```
     copy C:\Backup\System32.dll C:\Windows\System32
     ```
4. **Prevent Further Modifications:**
   - Enable Windows File Protection to prevent unauthorized system file changes:
     ```
     sfc /scannow
     ```

Scenario 19: Identifying Unauthorized Start-Up Programs Using Autorunsc
Background:
A user reports slow startup times and suspicious behavior on their machine. You suspect a malware or unauthorized application is launching at startup. Your goal is to audit and remove unnecessary startup programs.
Tasks:

1. **List All Startup Programs and Their Registry Entries:**
   - Identify unknown applications set to run on boot.
2. **Analyze Suspicious Start-Up Items:**
   - Verify legitimacy of all programs.
3. **Disable or Remove Malicious Entries:**
   - Prevent unauthorized applications from running at startup.

Solutions:

1. **List All Startup Programs:**
   - Run the following command:
     ```
     autorunsc -a
     ```
   - This provides a detailed list of everything configured to run on startup.
2. **Identify Suspicious Entries:**
   - Look for entries running from `%Temp%`, `%AppData%`, or other suspicious locations.
3. **Disable a Malicious Start-Up Program:**

- Run:
  `autorunsc -d "MaliciousProgram"`

Scenario 20: Enforcing Security Policy Compliance Using Secpol.msc
Background:
A recent audit revealed that some Windows workstations are not enforcing strong password policies and user account lockouts. Your goal is to ensure that the security policies are correctly implemented and enforced.
Tasks:

1. **Review Security Policies for Account Lockout and Password Strength:**
   - Ensure users follow best practices.
2. **Modify Policies to Enforce Stronger Security Measures:**
   - Configure stricter security settings.
3. **Verify That Policies Are Applied System-Wide:**
   - Ensure settings are active on all workstations.

Solutions:

1. **Open Local Security Policy Editor:**
   - Run:
     `secpol.msc`
2. **Navigate to Account Policy Settings:**
   - Check and update:
     `Account Policies → Password Policy`
   - Set `Minimum password length = 12`
   - Enable `Password must meet complexity requirements`
3. **Set Account Lockout Policy:**
   - Navigate to:
     `Account Policies → Account Lockout Policy`
   - Set `Account lockout threshold = 5`
   - Set `Reset account lockout counter after = 15 minutes`
4. **Force Group Policy Update:**
   - Run:
     `gpupdate /force`

Scenario 21: Auditing Weak Passwords and Detecting Compromised Accounts Using Pwdump
Background:
A company suspects that user credentials may have been leaked due to weak or compromised passwords. As an IT auditor, you are tasked with assessing the strength of Windows user passwords and verifying if any accounts are using easily crackable passwords. Your goal is to:

1. Extract Windows password hashes from the Security Account Manager (SAM) database.
2. Analyze the extracted hashes to check for weak or duplicate passwords.
3. Verify if any credentials have been exposed using common password cracking tools.
4. Implement security measures to prevent weak passwords and enforce stronger authentication policies.

Tasks & Solutions:

Step 1: Extracting Windows Password Hashes Using Pwdump
Since Windows stores user password hashes in the **SAM database**, you can use **Pwdump** to extract these hashes.

1. **Run Pwdump to Dump Windows Password Hashes:**
   - Open **Command Prompt (Admin)** and run:
     `pwdump > hashes.txt`
   - This will create a file `hashes.txt` containing all user password hashes.
2. **Verify Hash Extraction:**
   - Open the extracted file using:

`notepad hashes.txt`

- The output should list username and NTLM password hashes.

Step 2: Identifying Weak Passwords

Once the hashes are extracted, you can compare them with common weak passwords.

1. **Use a Hash Cracking Tool (e.g., John the Ripper or Hashcat)**
   - If using **John the Ripper**, run:
     `john --format=NT hashes.txt`
   - If using **Hashcat**, run:
     `hashcat -m 1000 hashes.txt rockyou.txt`
   - These tools will try to crack passwords using dictionary attacks.
2. **Identify Duplicate Passwords in the Organization**
   - Run a simple PowerShell command to check for duplicate hashes:
     `Get-Content hashes.txt | Select-Object -Unique`
   - If multiple users share the same hash, they are using identical passwords.

Step 3: Enforcing Stronger Password Policies

After identifying weak or compromised passwords, enforce stricter policies using **secpol.msc** and **gpedit.msc**.

1. **Open Local Security Policy:**
   - Run:
     `secpol.msc`
   - Navigate to:
     `Security Settings → Account Policies → Password Policy`
   - Set:
     - Minimum password length: `12`
     - Password complexity: `Enabled`
     - Maximum password age: `60 days`
2. **Force Users to Change Compromised Passwords:**
   - Reset affected accounts:
     `net user username *`
   - Set a temporary strong password, then force the user to change it on next login.

Step 4: Monitoring Future Password Changes and Compromised Accounts

1. **Enable Auditing for Account Logins and Failures:**
   - Open **Run (`Win + R`)**, type:
     `rsop.msc`
   - Navigate to:
     `Computer Configuration → Windows Settings → Security Settings → Local Policies → Audit Policy`
   - Enable **Audit logon events** and **Audit account management**.
2. **Check for Repeated Failed Login Attempts Using Event Viewer:**
   - Open Event Viewer (`eventvwr.msc`) and navigate to:
     `Windows Logs → Security → Event ID 4625 (Failed Logins)`
   - Look for repeated login failures, which may indicate brute-force attempts.
3. **Force a System-Wide Password Update:**
   - If multiple accounts are compromised, enforce an organization-wide password reset:
     `gpupdate /force`

Conclusion

Using **Pwdump**, you successfully extracted password hashes, identified weak or duplicate passwords, and enforced stronger security policies. Additionally, you enabled auditing to monitor future password changes and potential unauthorized access attempts. This ensures compliance with security best practices and reduces the risk of credential-based attacks.
